Análisis de Impacto en el Negocio

BIA · Del levantamiento con los dueños de los procesos al informe ejecutivo

Cátedra de Ciberseguridad · ESEN — Escuela Superior de Economía y Negocios

Ingeniería de Software y Negocios Digitales · Ciclo 2026

Docente: Ing. Héctor Cuchilla · Asignación especial de la Semana 2 · Insumo del entregable E.03 del Proyecto Final

ISO 22301:2019 · ISO/TS 22317:2021 · NIST SP 800-34 Rev. 1 · NIST SP 800-30 Rev. 1 · NIST CSF 2.0 · CIS Controls v8.1

Método de levantamiento

Métricas de tiempo

Cuantificación económica

Caso resuelto y actividad

Del impacto al riesgo y del riesgo al control

Tres análisis encadenados sostienen la decisión de invertir en seguridad, y cada uno entrega su resultado al siguiente.

1 · Análisis de impacto (BIA)

Qué pasa si el proceso se detiene y por cuánto tiempo se tolera. Entrega criticidad, métricas de tiempo, costo por hora y por día, AV, EF y SLE.

2 · Análisis de riesgos

Con qué frecuencia ocurrirá la amenaza (NIST SP 800-30 Rev. 1, 2012). Entrega ARO y ALE: la línea base de riesgo expresada en dinero al año.

3 · Evaluación de controles

Si la salvaguarda se paga a sí misma. Entrega el beneficio, el ACC y el ROSI: la decisión de invertir, con su sensibilidad.

Orden obligatorio. Quien salta el primer eslabón termina protegiendo lo que le resulta familiar en lugar de lo que sostiene a la organización. El costo por hora del BIA es el dato de entrada del análisis de riesgos.

ISO 22301:2019, cláusula 8.2; NIST SP 800-30 Rev. 1 (2012), Guide for Conducting Risk Assessments.

Qué es un BIA y dónde encaja en la continuidad del negocio

Definición: proceso de analizar el impacto que una interrupción produce en la organización a lo largo del tiempo (ISO 22301:2019, cláusula 3, términos y definiciones).

Su lugar en el ciclo

Dentro del ciclo de continuidad, el BIA y la evaluación de riesgos preceden a la definición de estrategias. Ninguna estrategia de recuperación se elige antes de conocer qué se recupera primero.

ISO/TS 22317:2021, segunda edición

Guía específica que desarrolla el método paso a paso. Cancela y reemplaza la edición de 2015, se alinea con ISO 22301:2019 y fue confirmada como vigente en la revisión sistemática de 2025.

NIST SP 800-34 Rev. 1 (2010)

La guía federal estadounidense de planificación de contingencia sitúa el BIA como el segundo paso de siete de su proceso de planificación.

Por qué va primero

Elegir primero la tecnología y buscar después el proceso que la justifique invierte el orden y produce planes que protegen lo familiar en lugar de lo esencial.

ISO 22301:2019; ISO/TS 22317:2021 (confirmada en 2025); NIST SP 800-34 Rev. 1 (2010), Contingency Planning Guide for Federal Information Systems.

La salida propia del BIA

Dos resultados que le pertenecen y que ninguna otra actividad entrega.

1

Lista priorizada de procesos

Los procesos de la organización y los activos que los sostienen, ordenados por criticidad en una lista única, con la clase de cada uno: crítico, importante o diferible.

2

Costo de la interrupción

Expresado por hora y por día de indisponibilidad, con las métricas de tiempo que fijan hasta cuándo la organización lo tolera: MTPD, RTO, WRT, RPO y MBCO.

Todo lo demás viene después. La probabilidad de la amenaza, la pérdida anual esperada y la decisión sobre el control pertenecen a los análisis siguientes y se alimentan de estos dos resultados. El BIA también entrega AV, EF y SLE, que son el puente hacia el análisis de riesgos.

ISO/TS 22317:2021, resultados del análisis de impacto; Guía del Estudiante BIA v6, sección 3.

El método completo en trece pasos

Cada paso deja su resultado en una plantilla de la asignación; al cerrar el paso trece, el informe ejecutivo queda completo y defendible.

Paso	Qué produce	Plantilla
1. Preparar y levantar	Método declarado, participantes y validación firmada.	P02
2. Inventariar los procesos	El universo del análisis.	P01
3. Fijar las métricas de tiempo	MTPD, RTO, WRT, RPO y MBCO, con su comprobación.	P02
4. Valorar el impacto en el tiempo	Matriz de cinco categorías por cinco cortes y el MTPD derivado.	P03
5. Estacionalidad y modo alterno	Peor escenario temporal y duración máxima sostenible.	P02
6. Mapear dependencias	Seis clases, recursos mínimos, puntos únicos de falla e interdependencias.	P04
7. Priorizar	Puntaje de criticidad y lista ordenada de procesos.	P05
8. Cuantificar	Costo por hora y por día, AV, EF y SLE.	P02
9. Cruzar la frontera	Entrega al análisis de riesgos: ARO y ALE.	P07
10. Justificar el control	Cinco pasos, ACC y ROSI.	P07
11. Declarar el método de valoración	Cuantitativo, cualitativo o semicuantitativo, y FAIR como alternativa.	P02 y P06
12. Probar los supuestos	Sensibilidad en escenarios mínimo, esperado y máximo.	P06
13. Redactar el informe ejecutivo	El documento que la dirección lee, discute y firma.	P07

Guía del Estudiante BIA v6, sección 4; plantillas BIA_P01 a BIA_P07 de la asignación; ISO/TS 22317:2021.

Paso 1 · El método de levantamiento

Los datos del BIA residen en el conocimiento de quien opera el proceso, y el analista los extrae con un método declarado.

1. **Entrevista estructurada**
   Con el dueño del proceso; aporta la profundidad y el matiz que ningún formulario captura.

2. **Cuestionario estandarizado**
   Cubre muchos procesos con el mismo criterio y hace comparables las respuestas.

3. **Taller**
   Reúne a las áreas que dependen unas de otras y saca a la luz las interdependencias que nadie declara por separado.

4. **Validación con el dueño**
   Cierra cada ficha: quien responde firma lo que respondió.

5. **Aprobación de la dirección**
   Convierte el resultado en la base oficial de la planificación, porque las métricas de tiempo que salen del BIA comprometen presupuesto.

Qué se registra en la P02

- Medios de levantamiento usados.
- Participantes con nombre y cargo.
- Fecha de cada entrevista o taller.
- Firma del dueño del proceso en la ficha validada.
- Aprobación de la dirección sobre las métricas de tiempo.

ISO/TS 22317:2021, recopilación de información para el BIA; Guía del Estudiante BIA v6, paso 1.

Paso 2 · El inventario de procesos de negocio

El trabajo empieza por enumerar los procesos. Un proceso se describe por lo que produce para alguien: la admisión de un paciente, la emisión de una factura, la entrega de un resultado de laboratorio.

Campo del inventario	Qué se registra	Ejemplo: admisión de pacientes
Nombre del proceso	Un verbo con su objeto.	Admitir al paciente
Área responsable	La unidad que lo ejecuta.	Admisión y registro
Dueño	Nombre y cargo de quien responde por él.	Jefatura de Admisión
Servicio que entrega	El resultado para su destinatario.	Paciente registrado con expediente abierto
Quién lo recibe	Cliente interno o externo.	Paciente y servicio clínico
Sistemas que lo soportan	Aplicaciones y plataformas, anotadas como dependencias.	Sistema de admisión y expediente clínico
Ventana de operación	Horario y días en que opera.	Veinticuatro horas, todos los días

El universo del análisis. Lo que no entra en el inventario no se analiza, y lo que no se analiza no se protege. El inventario se registra en la plantilla BIA_P01.

ISO/TS 22317:2021, determinación del alcance del BIA; plantilla BIA_P01_Inventario_Procesos.

Paso 3 · MTPD: el período máximo tolerable de interrupción

Definición: tiempo tras el cual la interrupción de un proceso produce un daño que la organización ya no puede revertir. También se abrevia MTD (ISO 22301:2019).

Pérdida de la licencia de operación

El regulador suspende la autorización para operar.

Incumplimiento contractual irreparable

El cliente rescinde o activa penalizaciones que no se recuperan.

Fuga masiva de clientes

Los clientes migran a la competencia y no regresan.

Riesgo para la vida de las personas

La interrupción compromete la integridad física de pacientes, usuarios o personal.

El MTPD lo fija el negocio. Es el límite duro del análisis: el dueño del proceso lo declara y la dirección lo aprueba. Todas las demás métricas de tiempo se acomodan por debajo de él.

ISO 22301:2019, términos y definiciones (maximum tolerable period of disruption); ISO/TS 22317:2021.

RTO y WRT: recuperar el sistema y recuperar el trabajo

La suma de ambos debe caber dentro del MTPD: es la comprobación de coherencia que todo BIA debe superar.

RTO · objetivo de tiempo de recuperación

Plazo máximo para restaurar el proceso y sus sistemas de soporte tras la interrupción (ISO 22301:2019).

WRT · tiempo de recuperación del trabajo

Plazo adicional para reconstruir los datos del período caído, validar la integridad y volver a la operación normal: reintroducir lo registrado en papel, conciliar inventarios, verificar resultados.

RTO + WRT ≤ MTPD

Si la desigualdad falla, la ficha no avanza.

Error frecuente. Olvidar el WRT: restaurar el sistema deja pendiente el trabajo del período caído.

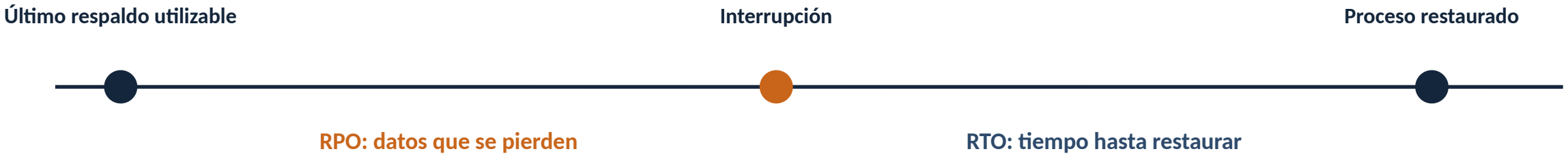
Ejemplo de incumplimiento

- RTO 2 h + WRT 3 h = 5 h sobre un MTPD de 4 h.
- El proceso queda operativo una hora después del límite que el negocio declaró irreversible.
- Corrección: acortar el RTO, acortar el WRT o justificar ante la dirección un MTPD mayor.

ISO 22301:2019 (recovery time objective); Guía del Estudiante BIA v6, paso 3.

RPO: cuánta información puede perderse

Definición: cantidad máxima de datos que la organización acepta perder, medida como el intervalo entre el último respaldo utilizable y el momento de la interrupción (ISO 22301:2019).



Qué gobierna

El RPO gobierna la frecuencia del respaldo y la tecnología de replicación. El RTO gobierna la capacidad de restauración.

Independientes entre sí

Se determinan por separado y cada uno con su propia justificación. Un RPO de cuatro horas significa que el proceso tolera perder hasta cuatro horas de transacciones.

Conviven en la misma organización

Un expediente clínico con RPO de quince minutos y un sistema de facturación con RPO de veinticuatro horas.

ISO 22301:2019 (recovery point objective); Guía del Estudiante BIA v6, paso 3.

MBCO: el objetivo mínimo de continuidad del negocio

Definición: nivel reducido de servicio que la organización debe sostener durante la contingencia, mientras la recuperación completa avanza (ISO 22301:2019).

Hospital

Atender urgencias sin cirugía programada.

Facturación

Facturar en modo diferido.

Comercio minorista

Operar el veinte por ciento de las cajas.

Qué declara

- Qué parte del proceso vuelve primero.
- Con qué capacidad opera durante la contingencia.
- Qué recursos mínimos exige ese nivel: personas, estaciones, red e instalación.

Por qué importa

Fijarlo obliga a distinguir entre lo que el proceso hace y lo que el proceso debe hacer para que la organización siga existiendo. Del MBCO se derivan los recursos mínimos de recuperación de la diapositiva 18.

ISO 22301:2019 (minimum business continuity objective); ISO/TS 22317:2021.

Las cinco métricas de tiempo en una tabla

Qué mide cada una, quién la fija y qué decide en la práctica.

Métrica	Qué mide	Quién la fija	Qué decide en la práctica
MTPD / MTD	Tiempo hasta el daño irreversible.	El negocio.	El límite duro de toda la planificación.
RTO	Plazo para restaurar el proceso y sus sistemas.	El negocio con tecnología.	La arquitectura de recuperación y el sitio alterno.
WRT	Plazo para reconstruir y validar el trabajo del período caído.	El dueño del proceso.	El personal de refuerzo tras la restauración.
RPO	Volumen de datos que se acepta perder, medido en tiempo.	El dueño del proceso.	La frecuencia del respaldo y la replicación.
MBCO	Nivel reducido de servicio durante la contingencia.	La dirección.	Los recursos mínimos que la contingencia exige.

Regla de cierre de la ficha. Todo proceso crítico tiene sus cinco métricas y cumple RTO + WRT ≤ MTPD antes de pasar a la priorización.

ISO 22301:2019; Guía del Estudiante BIA v6, paso 3; criterio J.1.3 del Proyecto Final.

Paso 4 · Las cinco categorías de impacto

El daño de una interrupción se evalúa en cinco categorías; cada una se estima por separado antes de consolidarse.

Financiero

Pérdida directa de ingresos, multas regulatorias, costos de remediación y compensaciones a clientes.

Operativo

Detención de la producción, interrupción de servicios dependientes y pérdida de productividad del personal.

Seguridad de las personas

Riesgo para la vida y la integridad física. En un hospital, una planta industrial o un servicio público esencial, esta categoría manda sobre las otras cuatro y decide por sí sola el orden de recuperación.

Legal y regulatorio

Incumplimiento de normativas, sanciones de las autoridades, pérdida de certificaciones y restricciones operativas impuestas.

Reputacional

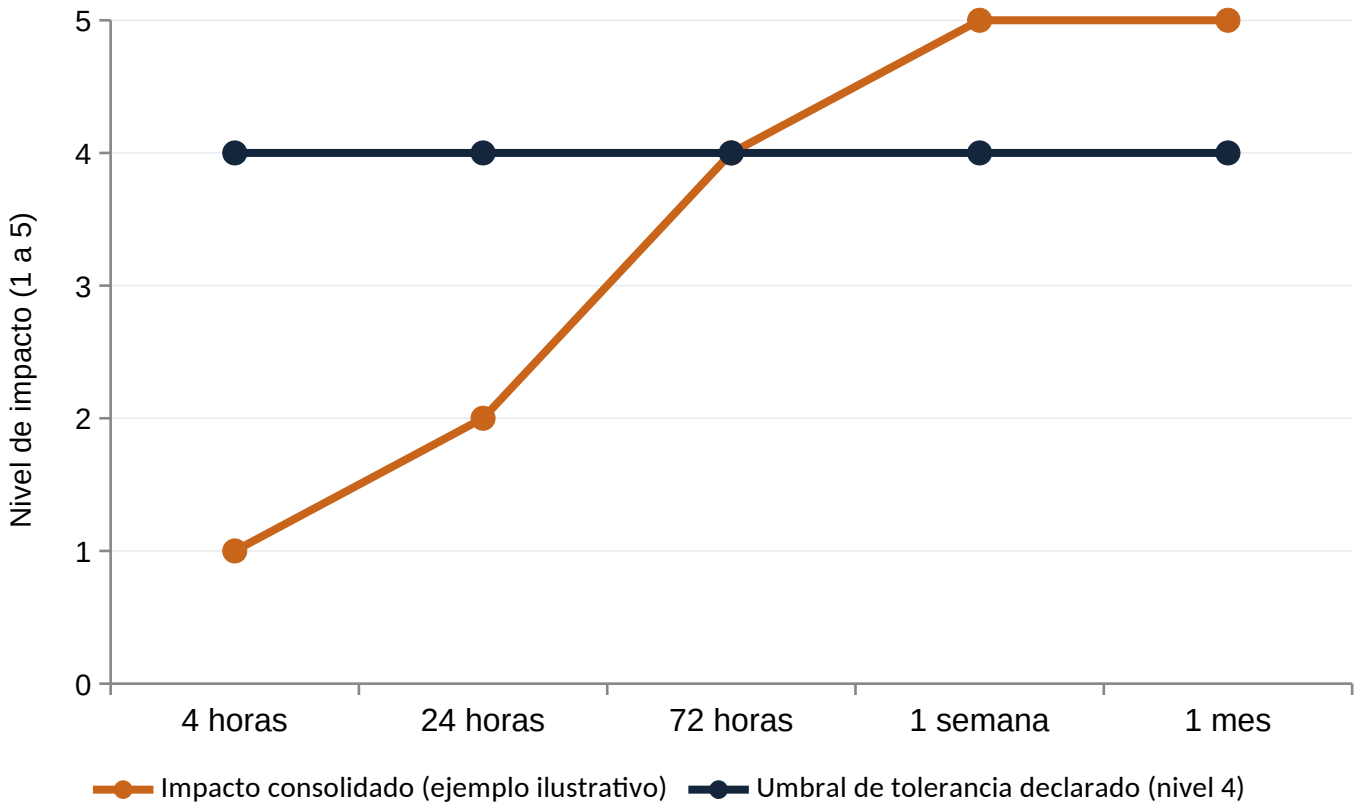
Pérdida de confianza de los clientes, cobertura negativa y deterioro de la marca.

Registro: plantilla BIA_P03, una fila por categoría y una columna por corte de tiempo.

ISO/TS 22317:2021, categorías de impacto; plantilla BIA_P03_Matriz_Impacto_Tiempo.

Las escalas de tiempo y el umbral de tolerancia

El impacto crece con la duración de la interrupción y rara vez lo hace de forma lineal. El corte en que la curva cruza el umbral determina el MTPD.



Nivel	Etiqueta
1	Bajo
2	Moderado
3	Alto
4	Grave
5	Crítico

Punto de inflexión

El corte en que el impacto se dispara.

Lectura del ejemplo

La dirección declara inaceptable el nivel 4. La curva lo alcanza en el corte de 72 horas, y ese corte fija el MTPD. El MTPD pasa a ser el resultado de una medición.

ISO/TS 22317:2021, impacto a lo largo del tiempo; escala de la plantilla BIA_P03. Curva con valores ilustrativos.

Paso 5 · Períodos pico y estacionalidad

El mismo proceso interrumpido produce daños distintos según el momento del año en que ocurre; la planificación de continuidad se dimensiona para el peor escenario temporal.

1

Facturación de un supermercado

Una interrupción un martes de febrero y la misma interrupción la víspera de Navidad producen pérdidas muy distintas.

2

Admisión hospitalaria

La demanda y la criticidad del proceso suben durante un brote estacional de enfermedad respiratoria o de dengue.

3

Nómina

La criticidad se concentra en los dos días de cada mes en que se calcula y se paga el salario.

Registro: plantilla BIA_P02, sección 6, «Períodos pico y estacionalidad».

Qué registra la ficha P02

- Los períodos pico de cada proceso y su causa.
- El corte de tiempo más sensible dentro del pico.
- La valoración del impacto sobre el peor caso temporal.

Regla de dimensionamiento. El impacto se valora en el peor escenario temporal, porque el promedio anual subestima la exposición del proceso.

ISO/TS 22317:2021, impacto a lo largo del tiempo; Guía del Estudiante BIA v6, paso 5; plantilla BIA_P02_Ficha_BIA_Proceso.

Procedimientos alternos y su duración máxima sostenible

Muchos procesos tienen una forma manual de seguir operando cuando el sistema cae; el BIA la documenta con precisión y declara cuánto tiempo se sostiene.

Registro en papel

Admisión, órdenes médicas, recepción de mercadería.

Autorización telefónica

Aprobación de transacciones y de accesos.

Hoja de cálculo local

Inventario, programación de turnos, cálculos de nómina.

1

Qué se hace

El procedimiento paso a paso, tal como lo ejecuta el personal.

2

Quién lo hace

Las personas y los roles que lo sostienen durante la contingencia.

3

Qué recursos exige

Formularios, teléfonos, equipos, espacio físico y personal de refuerzo.

4

Duración máxima sostenible

Horas o días de operación manual antes de que el volumen acumulado desborde al personal, la calidad se degrade o la reconstrucción posterior se vuelva impracticable.

Por qué se verifica

La duración máxima sostenible alarga el MTPD del proceso. Una duración declarada sin prueba alarga el MTPD sin respaldo; por eso se verifica con el dueño del proceso y se anota con su fuente.

ISO/TS 22317:2021; Guía del Estudiante BIA v6, paso 5. Ejemplo del caso RHM: registro en papel con duración máxima sostenible de 8 horas.

Paso 6 · El mapa de dependencias: seis clases

Ningún proceso opera solo. El BIA levanta seis clases de dependencia por cada proceso, y es la parte del análisis que más hallazgos produce.

1 Personas y competencias críticas

Quién sabe hacerlo y cuántas personas comparten ese conocimiento.

2 Aplicaciones y sistemas

Las plataformas que soportan el proceso y su modo de acceso.

3 Datos y registros vitales

Su ubicación, su formato y su respaldo.

4 Proveedores y terceros

El servicio que prestan y su propio compromiso de nivel de servicio (SLA).

5 Instalaciones

Dónde ocurre físicamente el trabajo.

6 Equipamiento y servicios básicos

Energía, climatización, conectividad y agua.

Registro: plantilla BIA_P04, sección 3. El mapa expone compromisos que nadie había escrito: el proveedor sin contrato de nivel de servicio, el respaldo que nadie ha restaurado, el conocimiento que vive en una sola persona.

ISO/TS 22317:2021, dependencias y recursos de las actividades priorizadas; plantilla BIA_P04_Mapa_Dependencias_Recursos.

Recursos mínimos de recuperación y puntos únicos de falla

De cada dependencia el análisis extrae dos datos: lo mínimo que la recuperación necesita y la dependencia sin alternativa.

Recurso mínimo de recuperación

- Cuántas personas.
- Cuántas estaciones de trabajo.
- Qué capacidad de red.
- Qué instalación.
- Todo dimensionado para operar en el nivel del MBCO, que siempre es menor que el requerimiento de la operación normal.

Punto único de falla (SPOF). La dependencia sin alternativa, cuya caída detiene el proceso por completo.

Persona

Una sola persona conoce el procedimiento.

Proveedor

Un único proveedor de un insumo.

Enlace

Un enlace de comunicaciones sin respaldo.

Servidor

Un servidor sin réplica.

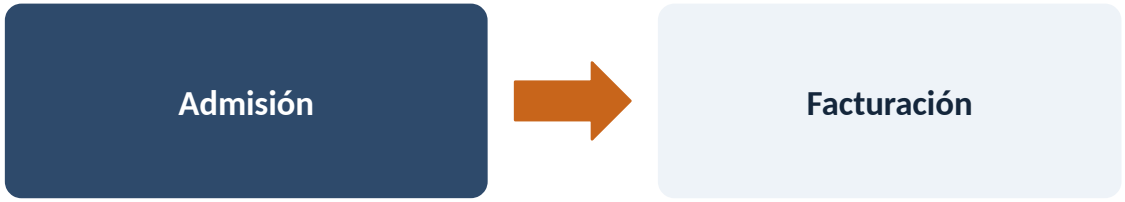
Destino del hallazgo: cada SPOF se registra con su proceso en BIA_P06 y pasa al informe ejecutivo.

Guía del Estudiante BIA v6, paso 6; plantillas BIA_P04 (sección 4) y BIA_P06 (sección 4).

Interdependencias entre procesos

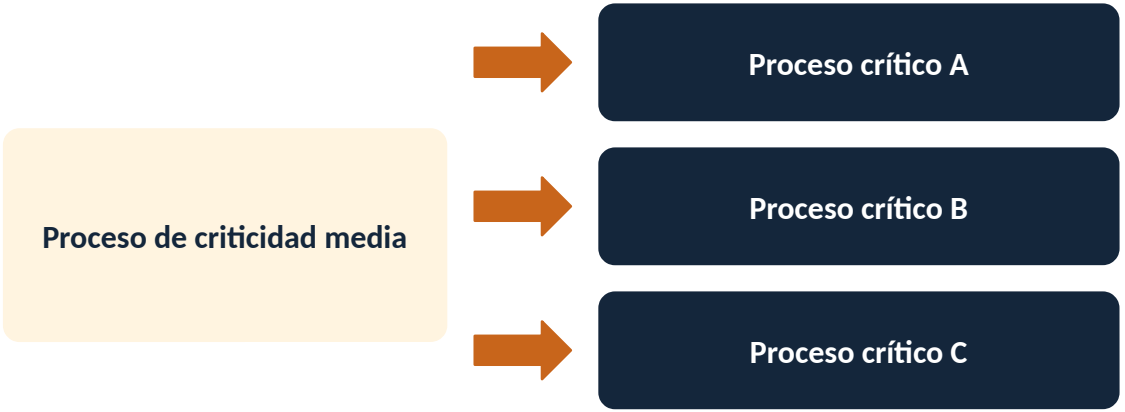
Los procesos dependen unos de otros, y esa red condiciona el orden de recuperación.

Secuencia de recuperación



La facturación opera con los datos de la admisión. La secuencia de recuperación pone primero la admisión, porque es la que produce el servicio que la facturación cobra.

Herencia de urgencia



Un proceso de criticidad media que alimenta a tres procesos críticos hereda la urgencia de aquellos a los que sostiene.

Registro: plantilla BIA_P04, secciones 5 y 6: por cada proceso, cuáles lo alimentan y cuáles se alimentan de él, y la secuencia de recuperación que resulta.

ISO/TS 22317:2021, interdependencias de las actividades; Guía del Estudiante BIA v6, paso 6.

Paso 7 · La matriz de criticidad y el puntaje de priorización

La priorización se resuelve con un puntaje explícito y reproducible: otro analista, con los mismos datos, llega al mismo resultado.

1. **Calificar**
   Cada proceso recibe una calificación en cada una de las cinco categorías de impacto, evaluada en el corte de 24 horas, el mismo para todos los procesos.

2. **Ponderar**
   Cada categoría lleva un peso acordado con la dirección; los pesos suman 100 %.

3. **Ajustar por dependientes**
   La suma ponderada se ajusta por el número de procesos que dependen del proceso analizado.

4. **Ordenar y clasificar**
   Lista única de procesos, clasificados como crítico, importante o diferible según rangos de puntaje declarados.

$$\text{Puntaje} = \Sigma\,(\text{calificación} \times \text{peso}) \times (1 + 0{,}10 \times n)$$

n = procesos que dependen del analizado · dos decimales, la mitad hacia arriba

Clase	Qué implica
Crítico	Se recupera primero; sus métricas de tiempo gobiernan la arquitectura de recuperación.
Importante	Se recupera a continuación, con recursos dimensionados a su MBCO.
Diferible	Se recupera cuando los críticos e importantes operan.

Registro: plantilla BIA_P05: pesos (sección 3), matriz (sección 4), reglas de clasificación (sección 5) y lista priorizada (sección 6).

Guía del Estudiante BIA v6, paso 7; Guía del Estudiante del Proyecto Final, E.03 (convención del puntaje); plantilla BIA_P05_Matriz_Criticidad_Priorizacion.

Paso 8 · Valor del activo, factor de exposición y SLE

La cuantificación económica del BIA termina en una cifra: la pérdida esperada por un evento único.

AV · valor del activo (Asset Value)

Valor económico total del activo o del proceso analizado: costo de reposición, valor de la información que contiene y flujo que genera.

EF · factor de exposición (Exposure Factor)

Proporción del valor que se pierde cuando el evento adverso ocurre, entre 0 y 1. Un incendio que destruye un centro de datos tiene un EF cercano a 1; una denegación de servicio de cuatro horas, uno mucho menor.

SLE = AV × EF

Pérdida esperada por evento único (Single Loss Expectancy)

Ejemplo: un proceso con AV de 200 000 dólares y EF de 0,40 arroja **SLE = 80 000 dólares por evento.**

El puente hacia el riesgo. El SLE responde cuánto cuesta el evento una vez que ocurre y es la última cifra del BIA. Cada escenario lleva su propio SLE y su EF; cada factor sale de la ficha de datos del cliente o se declara como supuesto.

Guía del Estudiante BIA v6, paso 8; plantilla BIA_P02, sección 9, «Valoración económica que el BIA entrega».

El costo de la indisponibilidad por hora y por día

La métrica más característica del BIA: responde qué se gana con la inversión en continuidad.

Componentes de cada hora de interrupción

- **Ingresos no percibidos.** Ventas, servicios o transacciones que dejan de facturarse.
- **Personal improductivo.** Salarios del personal detenido y horas extra de la recuperación.
- **Penalizaciones contractuales.** Cláusulas de nivel de servicio que se activan con la interrupción.
- **Costo de las medidas alternas.** Procedimiento manual, personal de refuerzo, servicios de emergencia.

Caso RHM · expediente clínico

12 000
dólares por hora

288 000
dólares por día (× 24)

48 000
dólares al alcanzar el MTPD de 4 horas: la cifra que va al informe ejecutivo

Uso: multiplicado por la duración esperada da el impacto del escenario; comparado entre procesos, ordena la inversión.

Guía del Estudiante BIA v6, paso 8 y ejercicio 6.1 (b); plantilla BIA_P02, sección 8. Cifras del caso: supuestos declarados del perfil del catálogo.

Paso 9 · Frontera entre el BIA y el análisis de riesgos

La frontera se traza por la probabilidad: el BIA responde qué pasa si el evento ocurre; el análisis de riesgos responde con qué frecuencia ocurrirá.

Pertenece al BIA	Pertenece al análisis de riesgos
Criticidad y lista priorizada de procesos	Tasa anualizada de ocurrencia (ARO)
MTPD, RTO, WRT, RPO y MBCO	Pérdida anual esperada (ALE = SLE × ARO)
Costo de indisponibilidad por hora y por día	Probabilidad de la amenaza y su fundamento
Valor del activo (AV) y factor de exposición (EF)	Comparación del riesgo contra el apetito declarado
Pérdida por evento único (SLE = AV × EF)	Selección y justificación económica del control

El BIA entrega: SLE, costo por hora, criticidad → **El análisis de riesgos añade: ARO → ALE**

Regla del Proyecto Final: la ficha E.03 entrega el SLE y deja el ARO y el ALE a la matriz de riesgos de E.05.

NIST SP 800-30 Rev. 1 (2012), Guide for Conducting Risk Assessments; Guía del Estudiante BIA v6, paso 9; plantilla BIA_P07, sección 7.

ARO y ALE: el cálculo del lado del riesgo

La cifra anual que se compara contra el costo anual de un control.

ARO · tasa anualizada de ocurrencia

Cuántas veces se espera que el evento ocurra en un año. Admite valores menores que uno: un evento esperado una vez cada cinco años tiene una tasa de 0,2.

ALE · pérdida anual esperada

Producto de la pérdida por evento único por la tasa anualizada. Es la línea base del riesgo expresada en dinero al año.

ALE = SLE × ARO

Annual Loss Expectancy = Single Loss Expectancy × Annualized Rate of Occurrence

80 000	0,5	40 000
SLE en dólares	ARO	ALE, dólares al año

Por qué se anualiza. El costo de un control se presupuesta por año; anualizar la pérdida permite comparar ambas cifras en la misma unidad.

NIST SP 800-30 Rev. 1 (2012); Guía del Estudiante BIA v6, paso 9.

Paso 10 · La justificación económica del control

La decisión de invertir se resuelve en cinco pasos; la inversión se justifica cuando el beneficio supera al costo.

1. **ALE actual, sin control adicional**
   La línea base del riesgo.

2. **Efectividad del control**
   Porcentaje en que reduce la pérdida por evento (EF) o la frecuencia (ARO), apoyado en especificaciones técnicas y estudios independientes.

3. **ALE con el control operando**
   Se recalcula con el EF o el ARO reducidos.

4. **Beneficio**
   ALE actual − ALE con control.

5. **Costo anual del control (ACC)**
   Adquisición anualizada, operación y mantenimiento.

Criterio de decisión

Beneficio > ACC

La salvaguarda se paga a sí misma.

Fuente de la efectividad

Especificaciones técnicas, pruebas y estudios. La cifra que ofrece el proveedor se contrasta con evidencia independiente antes de entrar al cálculo.

Guía del Estudiante BIA v6, paso 10; plantilla BIA_P07, sección 8, «Justificación económica del control, en cinco pasos».

ACC: el costo anual del control

Reúne todos los gastos recurrentes de implantar y sostener la contramedida, agrupados en tres familias que se suman siempre.

1

Adquisición

- Licencias de software anualizadas.
- Hardware y equipamiento.
- Implementación inicial repartida sobre su vida útil.

2

Operación

- Horas de personal dedicadas a gestión, monitoreo y administración.
- Consumo de recursos computacionales.

3

Mantenimiento

- Actualizaciones y parches.
- Soporte técnico.
- Capacitación continua del personal.

ACC = adquisición + operación + mantenimiento

Error frecuente. Omitir una familia infla el retorno aparente, y el presupuesto del año siguiente desmiente la decisión.

Guía del Estudiante BIA v6, paso 10; plantilla BIA_P07, sección 9. Ejemplo del ejercicio 6.1: ACC de 20 000 dólares = 9 000 + 7 000 + 4 000.

ROSI: el retorno de la inversión en seguridad

Expresa en porcentaje la eficiencia de la inversión y permite comparar controles entre sí.

ROSI = (Beneficio – ACC) ÷ ACC

Return on Security Investment, expresado en porcentaje

Para qué sirve

Compara controles entre sí y ordena el gasto: con presupuesto limitado, se financia primero el control con mayor retorno sobre el riesgo que reduce.

Ejemplo de cálculo

40 000
beneficio: reducción del ALE

15 000
ACC, dólares al año

25 000
beneficio neto

167 %
ROSI = 25 000 ÷ 15 000

Dependencia de origen. El valor del ROSI depende por completo de la calidad de las estimaciones que lo alimentan: AV, EF, ARO y efectividad. El rigor del BIA en su origen es lo que hace defendible la cifra.

Guía del Estudiante BIA v6, paso 10; plantilla BIA_P07, sección 10.

Paso 11 · Tres métodos de valoración y sus límites

Cada método tiene un costo en datos y un límite en precisión; el analista declara cuál usa y por qué.

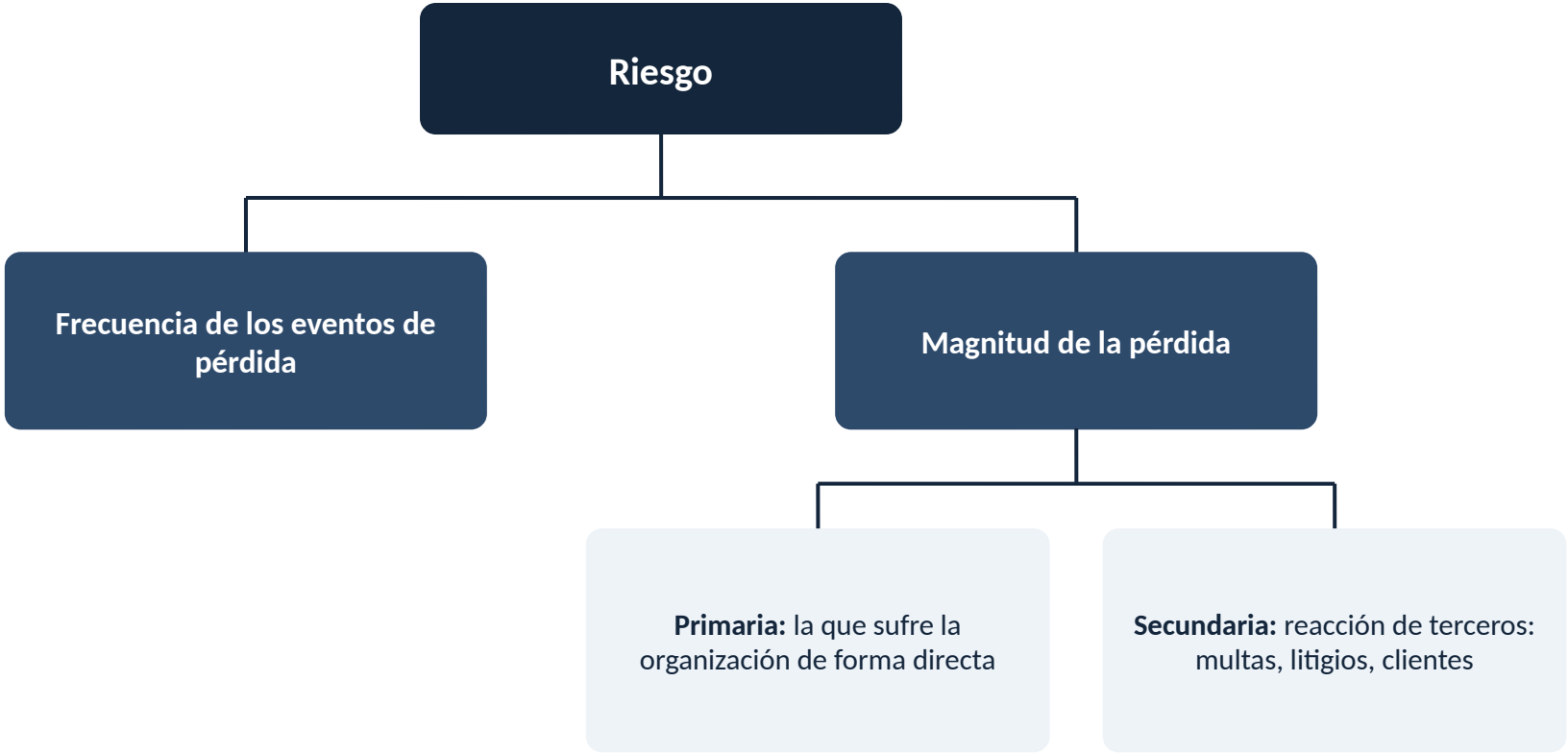
Método	Cómo valora	Ventaja	Límite
Cuantitativo	Asigna valores monetarios.	Cifras comparables y defendibles ante la dirección.	Exige datos históricos que muchas organizaciones no tienen.
Cualitativo	Escalas verbales: alto, medio, bajo.	Rápido y aplicable con poca información.	Dos analistas obtienen resultados distintos sobre el mismo caso.
Semicuantitativo	Asigna números a las categorías cualitativas.	Permite ordenar y ponderar conservando la simplicidad.	Los números conservan la naturaleza ordinal de su origen: sirven para ordenar y ponderar; la aritmética monetaria les es ajena.

Cuando faltan datos históricos: el analista declara el supuesto, documenta su fuente y lo somete al análisis de sensibilidad. El método elegido se registra en BIA_P02 (sección 10) y los supuestos en BIA_P06 (sección 3).

NIST SP 800-30 Rev. 1 (2012), enfoques cuantitativo, cualitativo y semicuantitativo; Guía del Estudiante BIA v6, paso 11.

FAIR: cuantificar con rangos en lugar de valores puntuales

Factor Analysis of Information Risk: taxonomía de riesgo publicada por The Open Group en sus normas Open FAIR, O-RT 3.0.1 y O-RA 2.0.1 (noviembre de 2021).



Qué aporta

Trabaja con rangos y distribuciones de probabilidad donde el esquema SLE–ARO –ALE usa valores puntuales.

Cuándo conviene

Cuando los datos históricos escasean, como en las empresas del catálogo.

Estado en el curso: alternativa disponible; se registra, si el equipo la usa, en BIA_P06, sección 6.

The Open Group, Risk Taxonomy (O-RT) Standard v3.0.1, C20B, y Risk Analysis (O-RA) Standard v2.0.1, C20A, noviembre de 2021.

Paso 12 · Análisis de sensibilidad sobre los supuestos

Todo BIA descansa en estimaciones; una conclusión se presenta como sólida cuando resiste la variación de sus supuestos.

1. **Declarar cada supuesto**
   Con su origen y su fecha, en el registro de supuestos.

2. **Variarlo en tres escenarios**
   Mínimo, esperado y máximo, para AV, EF y ARO.

3. **Observar el movimiento del resultado**
   Identifica las variables que gobiernan la conclusión.

Registro: BIA_P06, sección 3, y BIA_P07, sección 11.

Recomendación robusta

Se mantiene en los tres escenarios. El informe la presenta como tal.

Recomendación dependiente

Cambia de signo al variar un solo supuesto. El informe ejecutivo lo dice con esas palabras y nombra el supuesto que la gobierna.

NIST SP 800-30 Rev. 1 (2012), incertidumbre de la evaluación; Guía del Estudiante BIA v6, paso 12.

Paso 13 · El informe ejecutivo

El producto que la dirección lee, discute y firma: se escribe para quien decide el presupuesto, con la exposición en dinero y el plazo en horas que el negocio declaró.

Sección	Qué contiene
Resumen ejecutivo	Una página: exposición en dinero por unidad de tiempo, plazo de tolerancia, hallazgos que exigen decisión y recomendación con su costo.
Alcance y método	Procesos incluidos y excluidos con su razón, período, medios de levantamiento, participantes y método de valoración.
Procesos priorizados	Lista ordenada con clase y métricas de tiempo; RTO + WRT ≤ MTPD superada en todas las fichas.
Costo de la indisponibilidad	Por hora, por día y al alcanzar el MTPD, con el supuesto principal de cada cifra.
Puntos únicos de falla y brechas	Hallazgo, proceso afectado, consecuencia, acción propuesta y costo estimado.
Frontera con el análisis de riesgos	Qué entrega el BIA y qué corresponde al análisis de riesgos, declarado de forma explícita.
Justificación del control	Los cinco pasos, el ACC con sus tres familias y el ROSI.
Análisis de sensibilidad	Escenarios mínimo, esperado y máximo, y conclusión sobre la robustez.
Recomendaciones y aprobación	Decisión solicitada a la dirección y firmas.

Guía del Estudiante BIA v6, paso 13; plantilla BIA_P07_Informe_Ejecutivo.

Caso RHM · Paso 1: el BIA del expediente clínico

Red Hospitalaria Metropolitana (RHM): un hospital en San Salvador y tres clínicas especializadas, 950 empleados y cuatro procesos que el perfil declara críticos. Proceso analizado: la gestión del expediente clínico electrónico.

Resultado del levantamiento	Valor declarado
MTPD	4 horas
RTO	2 horas
WRT	2 horas para reintroducir lo registrado en papel
Comprobación RTO + WRT ≤ MTPD	2 + 2 = 4 ≤ 4 · cumple en el límite
RPO	15 minutos
MBCO	Consulta de solo lectura del historial de los pacientes ingresados
Procedimiento alterno	Registro en papel; duración máxima sostenible de 8 horas
Costo de la indisponibilidad	12 000 dólares por hora

Categoría dominante

Seguridad de las personas, en nivel máximo desde la primera hora: el personal médico decide sin historial de alergias, medicación previa ni resultados.

Puntos únicos de falla

- Segmentación laxa entre la red administrativa y la médica.
- Ausencia de inventario de los dispositivos médicos conectados.

Cifras del caso: supuestos declarados del ejercicio, tomados del perfil del catálogo; se someten al análisis de sensibilidad del paso 3.

Guía del Estudiante BIA v6, sección 5; Catálogo de Empresas del Proyecto Final ESEN 2026, perfil Red Hospitalaria Metropolitana.

Caso RHM · Paso 2: del BIA al análisis cuantitativo de riesgo

Escenario: cifrado del entorno del expediente clínico por un ataque de ransomware que aprovecha la segmentación laxa.

Variable	Valor	Origen
AV — valor del proceso	800 000 dólares	BIA
EF — factor de exposición	0,5: el respaldo recupera la mitad del valor sin pagar rescate ni reconstruir desde cero	BIA
SLE = AV × EF	400 000 dólares	BIA
ARO — tasa anualizada	0,4: exposición del sector salud y madurez baja de controles declarada en el catálogo	Análisis de riesgos
ALE = SLE × ARO	160 000 dólares al año	Análisis de riesgos

Frontera: aquí termina el BIA

400 000

SLE, dólares por evento

160 000

ALE, dólares al año: línea base del riesgo

Lo que añade el riesgo

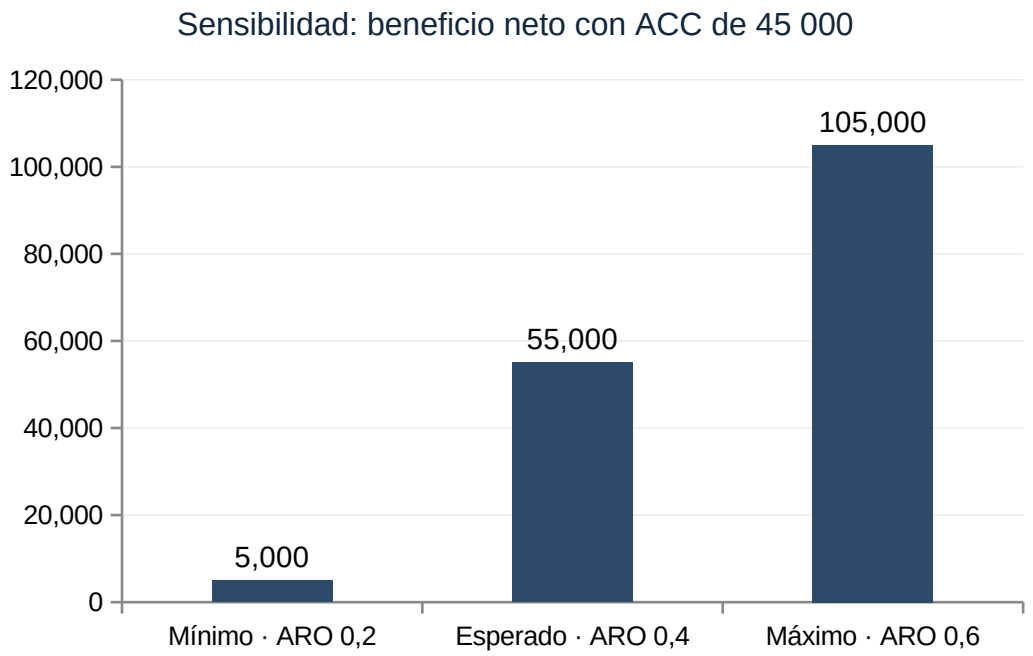
La probabilidad de la amenaza, estimada en la evaluación de riesgos.

Guía del Estudiante BIA v6, sección 5, paso 2; NIST SP 800-30 Rev. 1 (2012). Cifras: supuestos declarados del ejercicio.

Caso RHM · Paso 3: evaluar el control y decidir

Control: segmentación efectiva de la red médica más inventario y monitoreo de los dispositivos conectados. Efectividad: el ARO baja de 0,4 a 0,15.

Paso	Cálculo	Resultado
1. ALE actual	400 000 × 0,4	**160 000 $/año**
2. Efectividad	ARO 0,4 → 0,15	**Menor frecuencia**
3. ALE con control	400 000 × 0,15	**60 000 $/año**
4. Beneficio	160 000 − 60 000	**100 000 $/año**
5. ACC	Adquisición, operación, mantenimiento	**45 000 $/año**
Beneficio neto	100 000 − 45 000	**55 000 $/año**
ROSI	55 000 ÷ 45 000	**122 %**



Decisión. El beneficio neto se mantiene positivo en los tres escenarios del ARO: la recomendación es robusta y se presenta como tal. El margen del escenario mínimo es estrecho, de 5 000 dólares.

Guía del Estudiante BIA v6, sección 5, paso 3. Cifras: supuestos declarados del ejercicio.

Ejercicio guiado · Almacenamiento primario sin réplica

Mismo proceso del caso, escenario distinto. Resolver antes de ver la solución; las cifras son supuestos declarados del ejercicio.

Dato del ejercicio	Valor
MTPD declarado por la Dirección Médica	4 horas
RTO que propone el área de tecnología	3 horas
WRT estimado por el dueño del proceso	2 horas
Costo de indisponibilidad	12 000 dólares por hora
AV — valor del proceso	800 000 dólares
EF del escenario	0,25
ARO estimada por el análisis de riesgos	0,3
Control propuesto	Réplica sincrónica del almacenamiento con pruebas periódicas de restauración
Efectividad del control	EF de 0,25 a 0,10
ACC	20 000 $/año: 9 000 adquisición · 7 000 operación · 4 000 mantenimiento

1. **Se pide (a)**
   Verificar y corregir la coherencia de las métricas.
2. **Se pide (b)**
   Costo por día y al alcanzar el MTPD.
3. **Se pide (c)**
   Calcular el SLE.
4. **Se pide (d)**
   Calcular el ALE y decir a qué análisis pertenece.
5. **Se pide (e)**
   Evaluar el control en cinco pasos y obtener el ROSI.
6. **Se pide (f)**
   Sensibilidad con ARO de 0,2 y de 0,4.

Guía del Estudiante BIA v6, sección 6.1, ejercicio guiado con solución publicada.

Solución · Incisos (a) a (d)

Coherencia de las métricas, costo de la indisponibilidad, SLE y ALE.

(a) Coherencia de las métricas

- RTO 3 h + WRT 2 h = 5 h, que excede el MTPD de 4 h: la ficha queda detenida.
- Corrección: RTO de 2 h → 2 + 2 = 4 ≤ 4, cumple en el límite.
- Ampliar el MTPD queda descartado: la categoría que manda es la seguridad de las personas.

(b) Costo de la indisponibilidad

- Por hora: 12 000 dólares.
- Por día: 12 000 × 24 = 288 000 dólares.
- Al alcanzar el MTPD: 12 000 × 4 = 48 000 dólares, la cifra que va al informe ejecutivo.

SLE = 800 000 × 0,25 = 200 000

(c) Pérdida por evento único: la última cifra del BIA

ALE = 200 000 × 0,3 = 60 000

(d) Dólares al año: pertenece al análisis de riesgos (NIST SP 800-30 Rev. 1)

Frontera en el ejercicio: el BIA aporta el SLE; la tasa anualizada proviene de la evaluación de riesgos.

Guía del Estudiante BIA v6, sección 6.2, solución publicada.

Solución · Incisos (e) y (f)

Evaluación del control en cinco pasos y análisis de sensibilidad sobre el ARO.

Paso (e)	Cálculo	Resultado
1. ALE actual	200 000 × 0,3	**60 000 $/año**
2. Efectividad	EF 0,25 → 0,10; SLE = 800 000 × 0,10	**80 000 $**
3. ALE con control	80 000 × 0,3	**24 000 $/año**
4. Beneficio	60 000 − 24 000	**36 000 $/año**
5. ACC	9 000 + 7 000 + 4 000	**20 000 $/año**
Beneficio neto	36 000 − 20 000	**16 000 $/año**
ROSI	16 000 ÷ 20 000	**80 %**

Robusta con margen estrecho: se controla el costo del control tanto como su efectividad.

(f) Escenario	ARO	ALE actual	ALE con control	Beneficio	Neto	ROSI
Mínimo	0,2	40 000	16 000	24 000	4 000	20 %
Esperado	0,3	60 000	24 000	36 000	16 000	80 %
Máximo	0,4	80 000	32 000	48 000	28 000	140 %

Conclusión

El beneficio neto se mantiene positivo en los tres escenarios: la recomendación es robusta. Con ARO de 0,2 el retorno cae al 20 % y un desvío al alza del ACC de 4 000 dólares anula el beneficio; el informe declara ese margen estrecho.

Guía del Estudiante BIA v6, sección 6.2 (e) y (f). Cifras en dólares; supuestos declarados del ejercicio.

Actividad práctica · El BIA de la empresa del equipo

Cada equipo toma su empresa del catálogo, selecciona uno de sus procesos críticos declarados y recorre el método completo.

1. **Ficha del proceso**
   Cinco categorías en cinco cortes; MTPD derivado del umbral; RTO, WRT, RPO y MBCO con RTO + WRT ≤ MTPD.

2. **Dependencias**
   Seis clases mapeadas y al menos dos puntos únicos de falla.

3. **Cuantificación**
   Costo por hora y por día; AV, EF y SLE con sus supuestos.

4. **Cruce de frontera**
   ARO justificado, ALE, control con ACC y ROSI, y sensibilidad en tres escenarios.

Plantilla	Entregable
BIA_P01	Inventario de procesos
BIA_P02	Ficha BIA del proceso
BIA_P03	Matriz de impacto por categoría y corte
BIA_P04	Mapa de dependencias y recursos mínimos
BIA_P05	Matriz de criticidad y lista priorizada
BIA_P06	Supuestos, puntos únicos de falla y brechas
BIA_P07	Informe ejecutivo

Entrega en el Proyecto Final: E.03, hito H2, viernes 16 de octubre: hoja E03_BIA_Consolidacion_Procesos_Criticos más las siete plantillas como anexos obligatorios.

Guía del Estudiante BIA v6, sección 6.3; Guía del Estudiante del Proyecto Final ESEN 2026, entregable E.03 y calendario de hitos.

El enganche con los marcos y con el Proyecto Final

Los resultados del BIA alimentan funciones concretas de NIST CSF 2.0, controles concretos de CIS v8.1 y los entregables siguientes del proyecto.

NIST CSF 2.0 (2024)

Gobernar (GV): el apetito de riesgo declarado por la dirección.

Identificar (ID): la priorización de activos y procesos.

Recuperar (RC): los objetivos de tiempo que la planificación debe cumplir.

CIS Controls v8.1 (2024)

Controles 1 y 2: inventario de activos empresariales y de software, sostenidos por el mapa de dependencias.

Control 11: recuperación de datos, sostenido por los datos y registros vitales.

Proyecto Final

- E.03 consolida criticidad (P05), costo por hora (P07) y puntos únicos de falla (P06).
- E.05 continúa con ARO y ALE en la matriz de riesgos.
- La priorización sustenta el orden de implantación de las salvaguardas del IG asignado en el roadmap de E.10.



NIST CSF 2.0 (2024); CIS Critical Security Controls v8.1 (2024); Guía del Estudiante BIA v6, sección 7; Guía del Estudiante del Proyecto Final ESEN 2026.

Errores frecuentes y su corrección

Los diez errores que más se repiten en un BIA y lo que se hace en su lugar.

Error	Qué hacer en su lugar
Inventariar sistemas en lugar de procesos	Nombrar el proceso con un verbo y su objeto, y anotar el sistema como dependencia.
Que el área de tecnología fije el MTPD	Levantar el MTPD con el dueño del proceso y hacerlo aprobar por la dirección.
Olvidar el WRT	Aplicar siempre RTO + WRT ≤ MTPD antes de cerrar la ficha.
Confundir RTO con RPO	Determinarlos por separado, con su propia justificación.
Calcular el ALE dentro del BIA	Entregar el SLE y dejar el ARO y el ALE al análisis de riesgos.
Estimar el impacto en un solo momento del año	Registrar los períodos pico y valorar sobre el peor caso.
Suponer que el modo alterno se sostiene indefinidamente	Declarar y verificar la duración máxima sostenible.
Omitir familias de gasto en el ACC	Sumar adquisición, operación y mantenimiento, las tres.
Presentar una sola cifra sin supuestos	Declarar cada supuesto y variarlo en tres escenarios.
Hacer aritmética con escalas cualitativas	Usarlas para ordenar y ponderar.

Guía del Estudiante BIA v6, sección 8.

Referencias

Ediciones vigentes de las normas y guías citadas en la asignación.

Referencia	Uso en la asignación
ISO 22301:2019 — Sistemas de gestión de la continuidad del negocio. Requisitos	Definiciones de BIA, MTPD, RTO, RPO y MBCO.
ISO/TS 22317:2021 — Directrices para el análisis de impacto en el negocio (2.ª ed., confirmada en 2025)	Método paso a paso del BIA.
NIST SP 800-34 Rev. 1 (2010) — Contingency Planning Guide for Federal Information Systems	El BIA como segundo paso de siete.
NIST SP 800-30 Rev. 1 (2012) — Guide for Conducting Risk Assessments	ARO, ALE y evaluación cuantitativa del riesgo.
NIST CSF 2.0 (2024) — Cybersecurity Framework	Funciones de gobernar, identificar y recuperar.
CIS Critical Security Controls v8.1 (2024)	Controles 1, 2 y 11.
The Open Group — O-RT v3.0.1 (C20B) y O-RA v2.0.1 (C20A), noviembre de 2021	FAIR: frecuencia, magnitud y rangos.

Material de la asignación: Guía del Estudiante BIA v6 y plantillas BIA_P01 a BIA_P07, en la carpeta del Proyecto Final.

Lo que el estudiante se lleva

Un BIA bien hecho sustituye la petición de presupuesto por una cifra de exposición y un plazo de tolerancia que el propio negocio declaró y firmó.

1. Enumerar los procesos
2. Medir el impacto en el tiempo
3. Mapear las dependencias
4. Priorizar con un puntaje explícito
5. Poner precio a la hora de indisponibilidad
6. Entregar al análisis de riesgos

El mismo método en un banco, un hospital, un operador logístico o una institución pública. Su rigor vive en los supuestos declarados y en la sensibilidad que los pone a prueba.